

AtlasPay FinTech

SOC 2 Type 1 Readiness — Risk Register

DOCUMENT ID

**IFESEC-ATL-SOC2-
RR-20260625**

VERSION

v3.0

PERIOD

FY 2026 Q3 Audit Window

PREPARER

**IfeSec — ijezie Risk
Advisory**

CLASSIFICATION

CONFIDENTIAL

STATUS

Draft — Pending Review

AtlasPay FinTech — SOC 2 Type 1 Risk Register

Engagement: AtlasPay FinTech SOC 2 Type 1 Readiness Assessment **Period:** FY 2026 Q3 audit window (target)

Source of truth: CISO Assistant v3.18.3 (live state, folder d272ee78-ef71-4a70-8235-df2335cd0b3c) **Risk**

Assessment container: RA-ATLASPAY-SOC2 (AtlasPay SOC 2 Readiness Risk Assessment) **Risk Matrix:** AtlasPay 5x5 (5 probability levels × 5 impact levels)

Status Legend

-  **Covered** — Risk is designed and operating; controls in place
-  **Partial** — Risk treatment in progress; partial mitigation only
-  **Missing** — Risk treatment not yet designed
-  **[LAB-SYNTHETIC]** — Risk scenario or evidence is fabricated for portfolio demonstration; clearly marked; do not replicate for real client work without proper authorization

Scoring Methodology

Probability scale (1-5):

1. Unlikely (1-5%)
2. Rather unlikely (5-25%)
3. Likely (25-50%)
4. Very likely (50-80%)
5. Almost certain (80%+)

Impact scale (1-5):

1. Minor (negligible consequences)
2. Significant (limited consequences)
3. Serious (substantial consequences)
4. Critical (disastrous consequences)
5. Catastrophic (sector or regulatory consequences beyond the organization)

Risk levels (composite lookup):

- Very Low (1)
- Low (2)
- Medium (3)
- High (4)
- Very High (5)

Treatment options: Mitigate, Accept, Transfer, Avoid

Risk Register Summary

This table summarizes all 6 risk scenarios in scope. Detailed scenarios follow.

ID	RISK SCENARIO	CATEGORY	INHERENT	RESIDUAL	TREATMENT	OWNER
R-01	Privileged Account Compromise	Identity & Access	Very High (5)	Medium (3)	Mitigate	CISO
R-02	Payment Data Exfiltration via API	Data Security	Very High (5)	Medium (3)	Mitigate	CISO + CTO
R-03	Ransomware on Production Database	Availability	High (4)	Medium (3)	Mitigate	CTO + CISO
R-04	Third-Party SaaS Breach (Vendor Compromise)	Third-Party Risk	High (4)	High (4)	Accept	CISO + Vendor Mgmt
R-05	Insider Threat (Malicious Employee)	Human Risk	High (4)	Medium (3)	Mitigate	Head of People + CISO
R-06	Insufficient Audit Logging	Monitoring	High (4)	Low (2)	Mitigate	CISO + Engineering

Key takeaways:

- **4 of 6 risks** (R-01, R-02, R-03, R-06) have residual risk reduced to Medium or Low via documented controls
- **2 of 6 risks** (R-04, R-05) retain residuals at High or Medium, with treatment plans documented
- **R-04 is the only formally accepted residual High** — vendor compromise is endemic in FinTech
- **Inherent risk concentration:** 3 of 6 risks start at Very High (5) — typical for FinTech payment data

Risk Heat Map (Inherent vs Residual)

LIKELIHOOD ↓ / IMPACT →	NEGLIGIBLE (1)	MINOR (2)	SIGNIFICANT (3)	CRITICAL (4)	CATASTROPHIC (5)
Almost Certain (5)	—	R-06 (inh)	—	—	—
Very Likely (4)	—	—	—	R-04 (inh), R-05 (inh)	R-01 (inh), R-02 (inh)
Likely (3)	—	—	—	—	R-03 (inh)
Rather Unlikely (2)	—	—	R-02 (res), R-03 (res), R-05 (res)	—	R-01 (res)
Unlikely (1)	—	R-06 (res)	—	R-04 (res)	—

Notation: (inh) = inherent risk, (res) = residual risk after controls. Empty cells (—) indicate no risks currently at that combination.

Treatment Distribution

TREATMENT	COUNT	RISKS	RATIONALE
Mitigate	5	R-01, R-02, R-03, R-05, R-06	Controls reduce inherent risk to acceptable levels
Accept (with mitigation)	1	R-04	Vendor compromise is industry-endemic; mitigation focuses on blast-radius reduction

Detailed Risk Scenarios

R-01: Privileged Account Compromise

Category: Identity & Access **Owner:** CISO

Description: A privileged account (administrator, root, service account) at AtlasPay is compromised through credential theft, phishing, or insider abuse, allowing the attacker to escalate privileges, exfiltrate sensitive data, or disrupt production systems.

Inherent risk: Probability 4 (Very likely) × Impact 5 (Catastrophic) = **Very High (5)**

Existing controls:

- V-03 (Identity Provider) enforces SSO + MFA for all privileged access
- ACC-01 (Access Control Policy) defines privileged account provisioning, review, and revocation
- Privileged Access Management (PAM) tool sessions are recorded for audit
- Quarterly access reviews for all privileged accounts

Current risk: Probability 3 (Likely) × Impact 5 (Catastrophic) = High (4)

Residual risk: Probability 2 (Rather unlikely) × Impact 5 (Catastrophic) = **Medium (3)**

Treatment: Mitigate

- Continue PAM tool coverage expansion (currently 85% of privileged accounts)
- Annual red-team exercises targeting privilege escalation paths
- Continuous monitoring for anomalous privileged activity via V-05 (SIEM)
- Move toward just-in-time (JIT) privileged access provisioning (target Q4 2026)

Rationale for reduction: Identity provider controls (SSO + MFA) and PAM tooling materially reduce compromise probability. Impact cannot be reduced further without architectural changes (e.g., zero-trust) that exceed engagement scope.

R-02: Payment Data Exfiltration via API

Category: Data Security **Owner:** CISO + CTO

Description: Payment data (card numbers, transaction history, customer PII) is exfiltrated from AtlasPay's APIs through API key compromise, man-in-the-middle attack, or insider abuse.

Inherent risk: Probability 4 (Very likely) × Impact 5 (Catastrophic) = **Very High (5)**

Existing controls:

- V-02 (Payment Gateway) provides tokenization — no raw card data stored
- API gateway with mTLS for all internal service-to-service communication
- WAF with rate limiting and behavioral analysis
- DLP on egress traffic
- Quarterly penetration testing by external firm

Current risk: Probability 3 (Likely) × Impact 5 (Catastrophic) = High (4)

Residual risk: Probability 2 (Rather unlikely) × Impact 5 (Catastrophic) = **Medium (3)**

Treatment: Mitigate

- Continued penetration testing (quarterly)
- API key rotation cadence (90 days)
- Behavioral analytics on API traffic via V-05 (Monitoring Tools)

Rationale for unchanged residual: Controls are operating as designed. Additional residual reduction would require architectural changes (e.g., moving to zero-trust network segmentation) that exceed engagement scope.

R-03: Ransomware on Production Database Host

Category: Availability **Owner:** CTO + CISO

Description: Ransomware encrypts AtlasPay's production database host, rendering the system unavailable and potentially exfiltrating customer data before encryption.

Inherent risk: Probability 3 (Likely) × Impact 5 (Catastrophic) = **High (4)**

Existing controls:

- Immutable backup snapshots stored in isolated V-01 (AWS) account
- EDR (Endpoint Detection and Response) deployed on all production hosts
- Tested restore procedure (quarterly restore-from-backup drill)
- Network segmentation between production and corporate networks
- Principle of least privilege enforced via RBAC

Current risk: Probability 3 (Likely) × Impact 4 (Critical) = High (4)

Residual risk: Probability 3 (Likely) × Impact 3 (Serious) = **Medium (3)**

Treatment: Mitigate

- Continue quarterly restore-from-backup tests
- Annual tabletop exercise simulating ransomware scenario

-
- Continue EDR deployment and tuning

Rationale for unchanged residual: Impact was reduced (Critical to Serious) by demonstrating tested recovery capability, but probability remains unchanged because ransomware actors continue to evolve faster than defensive controls.

R-04: Third-Party SaaS Breach (Vendor Compromise)

Category: Third-Party Risk **Owner:** CISO + Vendor Management Officer

Description: A SaaS vendor in AtlasPay's supply chain (e.g., V-02 Payment Gateway, V-03 Identity Provider) is compromised, exposing AtlasPay customer data or disrupting operations.

Inherent risk: Probability 4 (Very likely) × Impact 4 (Critical) = **High (4)**

Existing controls:

- TPRM-01 (Third-Party Risk Management Policy) with vendor tier classification
- 7 vendors under MSA with security addenda
- Annual SOC 2 Type 2 review for Tier-1 vendors
- Contractual breach notification SLAs (72 hours)
- Vendor access segmentation via V-04 (Application Platform) service mesh

Current risk: Probability 4 (Very likely) × Impact 4 (Critical) = High (4)

Residual risk: Probability 3 (Likely) × Impact 4 (Critical) = **High (4)**

Treatment: Accept (with mitigation)

- Accept residual high because supply-chain compromise is endemic in FinTech
- Mitigate through blast radius reduction: vendor access segmentation, contractual recovery rights, sub-processor notification clauses
- Quarterly vendor risk review with focus on Tier-1 vendors (V-01, V-02, V-03)

Rationale for accepted High: Supply-chain attacks are a top-3 industry threat vector per Verizon DBIR 2025.

Architectural controls cannot eliminate the source. Mitigation focuses on reducing blast radius and recovery time, not on preventing the event.

R-05: Insider Threat (Malicious Employee)

Category: Human Risk **Owner:** Head of People + CISO

Description: A current or former employee with legitimate access misuses that access to exfiltrate data, sabotage systems, or facilitate external attack.

Inherent risk: Probability 4 (Very likely) × Impact 4 (Critical) = **High (4)**

Existing controls:

- Pre-employment background checks for all hires
 - Principle of least privilege enforced via RBAC
 - DLP on egress traffic
-

-
- User behavior analytics (UBA) via V-05 (SIEM)
 - Mandatory security awareness training (annual)
 - Offboarding procedure revokes access within 4 hours

Current risk: Probability 3 (Likely) × Impact 4 (Critical) = High (4)

Residual risk: Probability 2 (Rather unlikely) × Impact 4 (Critical) = **Medium (3)**

Treatment: Mitigate

- Annual security awareness training
- UBA tuning to detect anomalous data access patterns
- Quarterly access reviews by line managers
- Tabletop exercise simulating insider exfiltration scenario

Rationale for reduction: UBA and DLP controls have reduced the probability from Likely to Rather Unlikely based on observed false positive reduction over the past 12 months.

R-06: Insufficient Audit Logging

Category: Monitoring **Owner:** CISO + Engineering

Description: Critical system events are not logged, or logs are incomplete, making it impossible to detect or investigate security incidents effectively.

Inherent risk: Probability 5 (Almost certain) × Impact 2 (Significant) = **High (4)**

Existing controls:

- Centralized SIEM (V-05) aggregating logs from all production systems
- 90-day hot retention + 6-year cold archive per FFIEC retention pattern
- Log integrity verification via cryptographic hashing
- Alert rules for critical event types (auth failures, privilege escalation, data egress)
- Quarterly log coverage audit (verify all critical systems are logging)

Current risk: Probability 2 (Rather unlikely) × Impact 2 (Significant) = Low (2)

Residual risk: Probability 1 (Unlikely) × Impact 2 (Significant) = **Low (2)**

Treatment: Mitigate

- Continue quarterly log coverage audits
- Expand UBA rules to detect sophisticated exfiltration patterns
- Annual tabletop exercise testing incident detection and response

Rationale for substantial reduction: SIEM coverage has matured from 60% to 95% over the past 18 months. Remaining 5% gap is non-critical systems.

Risk Acceptance Statement

The following residual risks are formally accepted by AtlasPay management:

ID	RISK	RESIDUAL	ACCEPTED BY	DATE	REVIEW CADENCE
R-04	Third-Party SaaS Breach	High (4)	CISO + CEO	2026-06-25	Quarterly

Rationale: Supply-chain compromise is endemic in the FinTech sector. Architectural controls within engagement scope cannot eliminate the source of risk. Mitigation focuses on blast radius reduction, contractual recovery rights, and sub-processor notification clauses. The CISO and CEO acknowledge the residual High and accept it on behalf of AtlasPay, with quarterly review at Risk Committee meetings.

All other residual risks (R-01, R-02, R-03, R-05, R-06) are managed within AtlasPay's risk appetite and do not require formal acceptance.

Sign-Off

This risk register reflects the engagement state as of **2026-06-25**. The data in CISO Assistant v3.18.3 is the authoritative record. Lab-synthetic items are clearly marked and do not represent verified client evidence.

Prepared by: IfeSec Risk Advisory **Audience:** AtlasPay Board, CISO, Risk Committee **Next review:** Quarterly Risk Committee meetings (FY 2026 Q3 kickoff)